Where do we start with AI rules?

Business: Example Electrical Ltd Date: 23 October 2026

Sources checked: 19 October 2026; corrected points 23 October 2026

Start here: one step before anything else.

AI tools are in use with private accounts or without the business knowing which. Personal data goes in at least sometimes. The rules are a few sentences. The team has been briefed informally, without a record. First step: Set up business accounts with training on inputs switched off, and post the one page: what never goes into a tool.

What you told us

AI in use	Yes, with private accounts, or we do not know
Kinds of tools	AI built into Microsoft 365, Google Workspace or other business software
Personal data in tools	Sometimes
Written rules	A few sentences or an email
Briefing	Informally, without a record
Published AI output	No
Decisions about people	No

Where you stand

Business accounts, training on inputs off, tool register Private accounts or unknown data flows.	OPEN
Written usage policy with the one page to post A few sentences; not yet a policy.	PARTLY
Briefing with record (Article 4 AI Act) Happened, but nothing shows it.	PARTLY
Labelling check (Article 50 AI Act) No case at present; record it with a date.	NO CASE AT PRESENT
Decisions about people kept out Excluded; write it into the policy.	NOT USED

Findings

FACT The German data protection authorities advise that employees should not have to work with private accounts, because profiles of individual employees can arise; that accounts should be set at commissioning so that no inputs are used for training and no input history is kept beyond the session; that clear internal instructions should be issued and documented on whether, under which conditions and for which purposes AI applications may be used; and that removing names and addresses is regularly not enough to avoid personal data, because the connection to a person can be restored from the context.

→ German data protection conference (DSK), Orientierungshilfe "Künstliche Intelligenz und Datenschutz", version 1.0 of 6 May 2024, sections 2.2, 2.4, 2.5 and 3.1 · retrieved 2026-10-18

FACT Where a provider processes personal data on behalf of the business, the business may use only processors providing sufficient guarantees, and the processing is governed by a contract that sets out subject-matter, duration, nature and purpose, the type of data and the obligations of both sides. Controller and processor implement technical and organisational measures appropriate to the risk.

→ Regulation (EU) 2016/679 (GDPR), Art. 24(1), Art. 28(1) and (3), Art. 32(1), consolidated version of 4 May 2016 · EUR-Lex · retrieved 2026-10-19

FACT Article 4(1) of the AI Act asks providers and deployers to take measures to support the development of AI literacy of their staff and of other persons dealing with the operation and use of AI systems on their behalf, taking into account their knowledge, experience, education and the context of use; it does not require guaranteeing any specific level for any individual. The article has applied since 2 February 2025. The Commission writes that no certificate is needed and that organisations can keep an internal record of trainings.

→ Regulation (EU) 2024/1689, Art. 4(1) and Art. 113, point (a), consolidated version of 27 July 2026 · EUR-Lex · retrieved 2026-10-19; European Commission, AI literacy, questions and answers, page dated 27 July 2026 · retrieved 2026-10-18

INTERPRETATION Neither the AI Act nor the GDPR contains a provision that explicitly requires a written AI usage policy. Article 4 asks for measures that support literacy, Article 24(1) GDPR asks the controller for technical and organisational measures that are reviewed and updated, and the Trade Secrets Directive protects information only if reasonable steps were taken to keep it secret. A policy is the usual way to meet all three at once, not a duty of its own.

→ Regulation (EU) 2024/1689, Art. 4; Regulation (EU) 2016/679, Art. 24(1); Directive (EU) 2016/943, Art. 2(1), point (c) · retrieved 2026-10-18 and 2026-10-19

GAP How often a briefing is repeated and how long its record is kept is stated in no source we read. A new or changed tool is an obvious occasion to repeat; the business sets the rhythm.

◐ UNCERTAIN Which authority supervises Articles 4 and 50 is national law. Germany has named the Federal Network Agency (Act of 22 July 2026, in force since 29 July 2026). For Austria, as of 19 October 2026, no official source names the market surveillance authority; the duties apply regardless.

→ KI-Marktüberwachungs- und Innovationsförderungsgesetz of 22 July 2026, BGBl. 2026 I No. 223, § 2(1) · gesetze-im-internet.de · retrieved 2026-10-19; Datenschutzbehörde (Austria), page on artificial intelligence and data protection · dsb.gv.at · retrieved 2026-10-19

What to do next

- [ ] Business accounts for approved tools, training on inputs switched off, one row per tool in a register with the seven approval questions; no private accounts for work.
- [ ] Write the usage policy in nine areas: permitted tools and accounts, permitted and prohibited uses, what never goes in, handling unavoidable personal data, review before use, release of documents leaving the business, labelling, reporting incidents, responsibility in case of doubt. Post the one page.
- [ ] Brief the team: the policy section by section, what never goes in, two or three use cases from the business, the failure patterns, the reporting channel. Keep the attendance list with date and contents.
- [ ] Record "no labelling case at present" with a date, and ask again when AI output starts to reach customers or the public.
- [ ] Freeze an evidence page with the date: what is regulated, what is open, who is responsible, when it is reviewed next.

The AI Policy Toolkit produces the documents for every step of this plan: the usage policy, the one page to post, the tool register with approval form, the briefing record, the labelling checklist, the enactment plan and the evidence summary, from thirty-four questions, 29 of them required, with a handbook that marks every statement.

Sources

1. Regulation (EU) 2024/1689 of 13 June 2024 (AI Act), consolidated version of 27 July 2026: Art. 4, Art. 5(1)(f), Art. 26(2), Art. 50, Art. 113, Annex III point 4. eur-lex.europa.eu · retrieved 2026-10-19.
2. Regulation (EU) 2026/1744 of 8 July 2026 (Digital Omnibus on AI), in force since 27 July 2026: Art. 1, points (5), (39) and (40). eur-lex.europa.eu/eli/reg/2026/1744/oj · retrieved 2026-10-18.
3. Regulation (EU) 2016/679 (GDPR), consolidated version of 4 May 2016: Art. 24(1), Art. 28(1) and (3), Art. 32(1). eur-lex.europa.eu · retrieved 2026-10-19.
4. Directive (EU) 2016/943 on the protection of trade secrets: Art. 2(1)(c). eur-lex.europa.eu · retrieved 2026-10-18.
5. European Commission, AI literacy, questions and answers, page dated 27 July 2026. digital-strategy.ec.europa.eu/en/faqs/ai-literacy-questions-answers · retrieved 2026-10-18. Guidance, not law.
6. European Commission, Guidelines on the transparency obligations under Article 50, content approved on 20 July 2026 (C(2026) 5054 final, annex), point 131. digital-strategy.ec.europa.eu · retrieved 2026-10-23. To be checked: formal adoption in all languages. Guidance, not law.

7. Datenschutzkonferenz (German data protection authorities), Orientierungshilfe "Künstliche Intelligenz und Datenschutz", version 1.0 of 6 May 2024, sections 1.9, 2.2, 2.4, 2.5, 3.1. datenschutzkonferenz-online.de · retrieved 2026-10-18. Guidance, not law.
8. Germany: KI-Marktüberwachungs- und Innovationsförderungsgesetz of 22 July 2026, BGBl. 2026 I No. 223, § 2(1). gesetze-im-internet.de · retrieved 2026-10-19. Austria: Datenschutzbehörde, page on artificial intelligence and data protection, undated. dsb.gv.at · retrieved 2026-10-19.

This memo is information based on the sources listed, generated on 23 October 2026 from the answers above. It is not legal advice and decides nothing on behalf of your business. Every statement carries its marker, every source its retrieval date; check the sources again before you rely on a date.